

Quantifier le capital d'un défaut de conformité DORA

Une cascade dirigée entre les cinq piliers, et la frontière de ce qui est mesurable

Kélian Kaddouri • ENSAE / Nexialog Consulting • résumé exécutif

La thèse en une phrase. La dépendance entre les cinq piliers de DORA n'est pas une corrélation mais une **propagation orientée**; or cette orientation *n'est pas mesurable* sur les données publiques. Plutôt que de la poser en silence, ce mémoire en établit la **frontière d'identifiabilité**, publie le capital en **bornes** sur tout ce que la donnée laisse ouvert, et transforme la donnée manquante en **spécification de reporting chiffrée et hiérarchisée**.

Le modèle. Un incident amorcé sur un pilier se propage aux autres selon une matrice d'influence *asymétrique* W , normalisée à la Leontief : la stabilité du système est **garantie par construction**, non supposée. La sévérité est une Pareto généralisée (théorie des valeurs extrêmes), la fréquence une négative binomiale, et l'état de conformité de l'entité pilote le capital par une couche multi-états markovienne, d'où une **trajectoire** de capital plutôt qu'un chiffre. Là où la Formule Standard, qui ne dépend que du volume, est structurellement **aveugle** à la conformité.

La contribution centrale : une frontière, pas une mesure. Sur deux sources qui échouent pour des raisons *opposées* (l'une manque de taxonomie, l'autre de résolution temporelle), et jusque sur la meilleure expérience naturelle disponible (le choc de chaîne d'approvisionnement MOVEit, où l'effet apparent est intégralement absorbé par un placebo), on démontre que la **direction** de la contagion n'est pas identifiable, quand sa **co-occurrence** l'est. La théorie des processus réversibles en donne la raison de principe : la direction est un *courant* qui change de signe sous renversement du temps, et aucune statistique invariante par ce renversement ne peut l'identifier.

Ce que la donnée fixe, ce qu'elle ne fixe pas, et ce qu'on en fait.

- **Fixé** et validé : la queue de sévérité (ajustement non rejeté, $p = 0,87$ par bootstrap paramétrique), la surdispersion de la fréquence ($p \approx 10^{-30}$), la co-occurrence entre piliers, l'accumulation par prestataire tiers.
- **Non fixé** : la direction. Elle est donc **bornée**, jamais posée, et le capital est lu sur l'ensemble entier des matrices admissibles.
- **Corroboré** sans élicitation : le codage de sept post-mortems officiels (CSRB, FCA/PRA, GAO, SEC, OCC) donne une orientation *cohérente* d'un rapport à l'autre, et un traitement bayésien conjugué en tire une loi a posteriori qui *reproduit d'elle-même* la structure d'identification, robuste à un prior sceptique (0,8 % d'écart).

Les résultats qui résistent. Le **niveau** du capital est illustratif : il bouge d'un facteur 40 selon la source de sévérité, d'un facteur 5,5 selon la famille de loi de queue, et d'un facteur 2,6 par la seule incertitude d'estimation. Ce qui **résiste** est ailleurs, et c'est ce que le mémoire défend : le **classement des piliers** (gouvernance et gestion des tiers dominant robustement les trois autres, dans tous les cadres de dépendance testés), les **rapports** entre états de conformité, et l'**ordre de remédiation**. Trois étages d'incertitude sont nommés et chiffrés séparément : paramètre, identification, et **modèle** (le choix de la famille elle-même) — ce dernier étage étant celui que la plupart des travaux passent sous silence.

La portée réglementaire. La limite devient un livrable. Le registre d'incidents qui identifierait la contagion est spécifié (horodatage de survenance au mois, taxonomie par domaine de contrôle, causes communes consolidées), et surtout **hiérarchisé** : documenter une seule dépendance inter-piliers lève jusqu'à 29 % de l'ambiguïté de capital, une autre n'en lève rien. La recommandation cesse d'être générique. En regard, chaque indicateur observable (délai de notification, durée de confinement, concentration tierce) est rattaché à un canal du modèle et devient un **levier de capital priorisable**, ce qui fait de la conformité un arbitrage économique et non un pur coût.

Ce que ce mémoire ne prétend pas. Le niveau absolu du capital n'est pas une mesure et n'est jamais présenté comme telle : l'agrégat obtenu est d'échelle sectorielle, non celui d'une entité isolée. La direction de la contagion n'est pas calibrée, seulement bornée et corroborée, avec son confondant déclaré (une enquête officielle cherche par convention une cause racine de gouvernance, ce qui peut orienter la lecture). Connaître le sens d'un lien ne donnerait d'ailleurs pas sa force : même les dix directions établies, une bande subsisterait. **L'identification partielle n'est donc pas un pis-aller provisoire, elle est structurelle** — et c'est précisément ce que le mémoire assume, chiffre et documente, plutôt que de le masquer derrière un nombre unique.

Mots-clés. Risque cyber • DORA • SCR • Solvabilité II • valeurs extrêmes • cascade dirigée • identification partielle • bornes de capital • inférence bayésienne • valeur de l'information.